



UNIVERSIDAD NACIONAL DE INGENIERÍA

"Ciencia y Tecnología al Servicio del País"

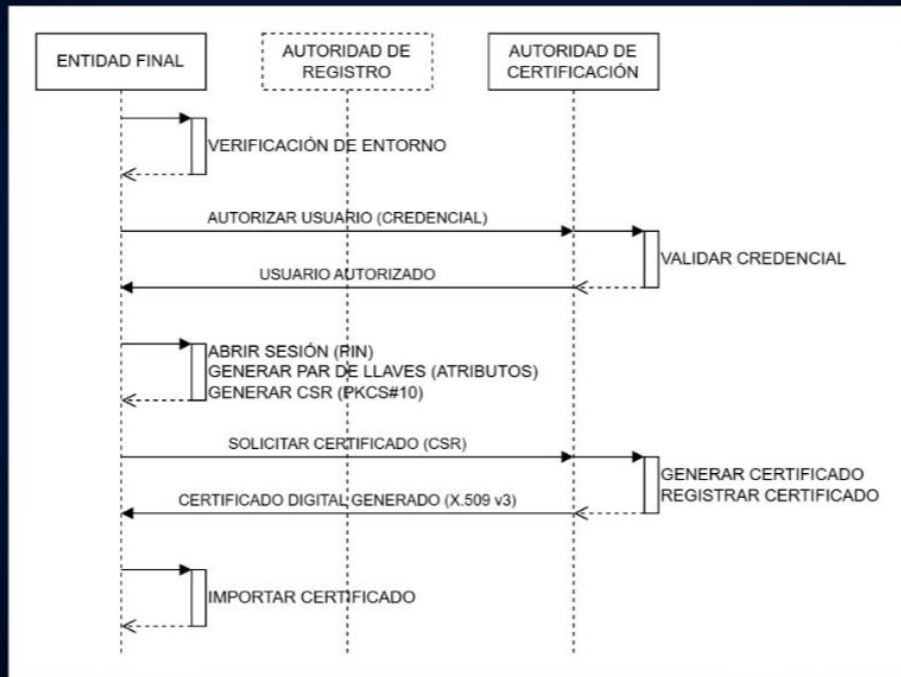
DIGITAL CERTIFICATION



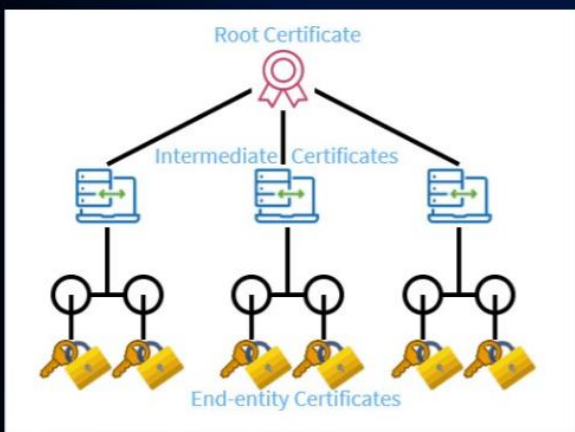
- SE PUEDE USAR UN CERTIFICADO DIGITAL EMITIDO POR UNA AUTORIDAD DE CERTIFICACIÓN (CA) PERTENECIENTE A UNA JERARQUÍA DE CERTIFICACIÓN DIGITAL IMPLEMENTADA A TRAVÉS DE UNA INFRAESTRUCTURA DE LLAVE PÚBLICA (PKI).
- ESTE CERTIFICADO DIGITAL PERMITIRÁ AUTENTICAR LA IDENTIDAD DIGITAL DE UNA ENTIDAD (REMITENTE, EMISOR O CLIENTE) DE FORMA VERIFICABLE.
- LOS CERTIFICADOS DIGITALES BRINDAN UN ALTO NIVEL DE CONFIANZA EN LA ENTIDAD (PERSONA O SISTEMA DE INFORMACIÓN) CON LA QUE SE ESTÁ COMUNICANDO.
- UNA ENTIDAD QUE DESEA OBTENER UN CERTIFICADO DIGITAL EMITIDO POR UNA CA, SOLICITA EL CERTIFICADO A TRAVÉS DE UNA AUTORIDAD DE REGISTRO (RA), DEBIENDO PROPORCIONAR ALGUNA PRUEBA DE IDENTIDAD PARA VERIFICAR LA IDENTIDAD DECLARADA POR EL SOLICITANTE.
- SI LA VERIFICACIÓN DE LA RA TUVO UN RESULTADO EXITOSO, LA CA EMITE UN CERTIFICADO DIGITAL A LA ENTIDAD.



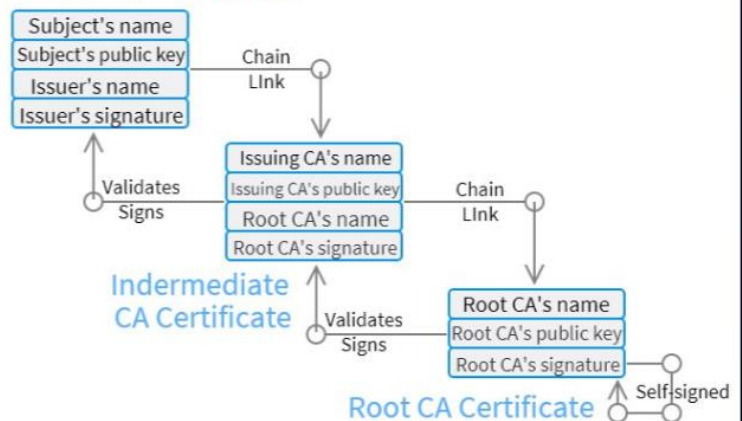
- ESTE CERTIFICADO CONTIENE LA LLAVE PÚBLICA DEL SOLICITANTE Y LOS DATOS PÚBLICOS DE LA ENTIDAD FIRMADOS UTILIZANDO LA LLAVE PRIVADA DE LA CA.
- ESTE CERTIFICADO ES UTILIZADO COMO PRUEBA DE IDENTIDAD DE LA ENTIDAD.
- EL CERTIFICADO SE ADJUNTA AL CORREO ELECTRÓNICO O LAS TRANSACCIONES WEB QUE LA ENTIDAD REALIZA COMO PARTE DE LA CREDENCIAL DE AUTENTICACIÓN.
- EL RECEPTOR VERIFICA EL CERTIFICADO DE LA ENTIDAD CON LA LLAVE PÚBLICA DE LA CA
- TAMBIÉN VERIFICA QUE LA CA NO HA COLOCADO EL CERTIFICADO DE LA ENTIDAD EN LA LISTA DE CERTIFICADOS REVOCADOS (CRL) GESTIONADO POR LA CA.
- OPCIONALMENTE, SE PUEDE ENVIAR UNA CONSULTA DEL ESTADO DEL CERTIFICADO A UN SERVICIO UTILIZANDO EL PROTOCOLO DE VERIFICACIÓN DE ESTADO DEL CERTIFICADO ONLINE (OCSP), TAMBIÉN CONOCIDO COMO OCSP RESPONDER.



5



End-entity Certificate



6



CAMPO	DESCRIPCIÓN
Version	EXISTEN 3 VERSIONES; LA PRIMERA (1) CON VALOR 0, SOPORTA SOLO CAMPOS BÁSICOS, LA SEGUNDA (2) CON VALOR 1, QUE AGREGA IDENTIFICADORES ÚNICOS, Y LA TERCERA (3) CON VALOR 2, INCLUYE EXTENSIONES. LOS CERTIFICADOS EMITIDOS HOY, SON DE LA VERSIÓN 3.
serialNumber	DEBE SER UN NÚMERO NO SECUENCIAL CON UNA LONGITUD DE AL MENOS 64 BITS DE ENTROPÍA IMPREDECIBLE. IDENTIFICA A UN CERTIFICADO EMITIDO POR UNA CA.
signatureAlgorithm	ESPECIFICA EL ALGORITMO UTILIZADO CON EL QUE SE GENERÓ (FIRMÓ) EL CERTIFICADO. ES COLOCADO EN EL CERTIFICADO PARA SER PROTEGIDO POR LA FIRMA, Y ES ESPECIFICADO DE ACUERDO CON EL RFC3279.
issuer (DN)	CONTIENE EL NOMBRE ÚNICO (DN: DISTINGUISHED NAME) QUE IDENTIFICA A LA ENTIDAD QUE HA FIRMADO EL CERTIFICADO. ESTE CAMPO SE DEFINE DE ACUERDO CON EL ESTÁNDAR X.501 Y MEDIANTE LA ESTRUCTURA ASN.1.
validity	DEFINE EL INTERVALO DE TIEMPO DURANTE EL CUAL EL CERTIFICADO ES VÁLIDO, Y ES REPRESENTADO CON DOS VALORES: LA FECHA DE INICIO Y LA FECHA DE TÉRMINO.
subject (DN)	ES EL NOMBRE ÚNICO DE LA ENTIDAD PARA EL CUAL EL CERTIFICADO ES EMITIDO. CERTIFICADOS AUTOFIRMADOS TIENEN EL MISMO DN EN LOS CAMPOS ISSUER Y SUBJECT.
subjectPublicKeyInfo	CONTIENE LA LLAVE PÚBLICA.

7



ATRIBUTO	SIGNIFICADO	FUNCIÓN	OTROS ATRIBUTOS	SIGNIFICADO
CN	Common Name	IDENTIFICA DE FORMA PRINCIPAL AL SUJETO O ENTIDAD CERTIFICADA.	L	Locality
OU	Organization Unit	IDENTIFICA EL ÁREA O DEPARTAMENTO DENTRO DE LA ORGANIZACIÓN.	ST	State/Province
O	Organization	DEFINE LA INSTITUCIÓN PROPIETARIA DEL CERTIFICADO.	STREET	Address
C	Country	CÓDIGO ISO DE DOS LETRAS DEL PAÍS.	DC	Domain Component
			EMAILADDRESS	Email address

- EL DN REPRESENTA LA IDENTIDAD TEXTUAL Y JERÁRQUICA DE UNA ENTIDAD.
- EL CERTIFICADO DIGITAL VINCULA ESA IDENTIDAD CON UNA LLAVE PÚBLICA.
- PERMITE UNICIDAD DENTRO DE UNA PKI Y FACILITA PROCESOS COMO:
 - AUTENTICACIÓN.
 - VALIDACIÓN DE CERTIFICADOS.
 - CONTROL DE ACCESO.
 - DIRECTORIOS LDAP.
 - FIRMA DIGITAL.
- EL CERTIFICADO NO "PROTEGE" LA LLAVE PÚBLICA; LO QUE HACE ES:
 - AUTENTICARLA.
 - ASOCIARLA A UNA IDENTIDAD VERIFICABLE.
 - FIRMAR CRIPTOGRÁFICAMENTE ESA ASOCIACIÓN.
- LA CA IDENTIFICADA POR issuerDN CERTIFICA QUE LA LLAVE PÚBLICA subjectPublicKeyInfo PERTENECE AL SUJETO IDENTIFICADO POR subjectDN DURANTE EL PERIODO validity, USANDO EL ALGORITMO signatureAlgorithm, Y BAJO EL IDENTIFICADOR serialNumber.

8

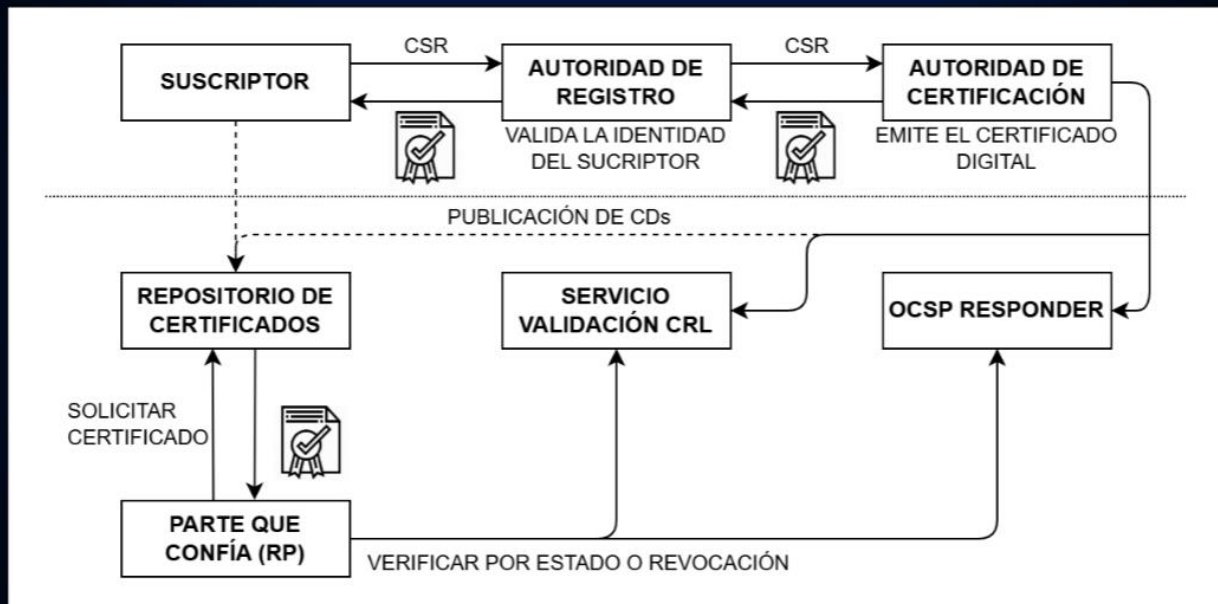


CERTIFICATE EXTENSIONS

- KeyUsage
- ExtendedKeyUsage
- BasicConstraints
- SAN
- CRL Distribution Points
- Authority Information Access

CERTIFICATE VALIDATION PROCESS

1. VERIFY SIGNATURE
2. VERIFY CHAIN
3. VERIFY EXPIRATION
4. VERIFY REVOCATION
5. VERIFY KEY USAGE / EKU



- OCSP <https://www.rfc-editor.org/rfc/pdf/rfc/rfc6960.txt.pdf>



LAS FUNCIONES DE UNA PKI:

- REGISTRO DE UNA CA.
- INICIALIZACIÓN Y CONFIGURACIÓN DE OTRAS CA.
- GESTIÓN DOCUMENTAL (POLÍTICA Y DE DECLARACIÓN DE PRÁCTICAS DE CERTIFICACIÓN)
- GESTIÓN DE LLAVES (PKI MANAGEMENT)
 - GENERACIÓN DE LLAVES.
 - REGENERACIÓN DE LLAVES.
 - GENERACIÓN DE CERTIFICADOS SUBORDINADOS.
 - GENERACIÓN DE LA LISTA DE CERTIFICADOS REVOCADOS.
 - RECUPERACIÓN DE LLAVES: LA LLAVE PRIVADA DE LA ENTIDAD PUEDE SER RESPALDADA POR UNA CA O POR UN SISTEMA DE RESPALDO DE LLAVES SEPARADO. SI ESTÁ CONTEMPLADO EN SU POLÍTICA DE CERTIFICACIÓN, LA PKI DEBE PROPORCIONAR UN SISTEMA QUE PERMITA LA RECUPERACIÓN DE LA LLAVE PRIVADA CON UN RIESGO MÍNIMO.
 - ARCHIVO DE LLAVES.
 - DESTRUCCIÓN DE LLAVES.
- PUBLICACIÓN DE CERTIFICADOS Y DE LAS CRL ASOCIADAS EN UN REPOSITORIO PÚBLICO.
- DE CORRESPONDER, CERTIFICACIÓN CRUZADA.



TIPO DE REPOSITORIO	DESCRIPCIÓN
REPOSITORIO DE CERTIFICADOS	ES UN SERVICIO DE DIRECTORIO SOBRE UNA RED, LDAP ES UNA DE LAS IMPLEMENTACIONES MÁS UTILIZADAS; ACTIVE DIRECTORY ES UNA IMPLEMENTACIÓN PROPIETARIA AMPLIAMENTE USADA.
CRL: CERTIFICATE REVOCATION LIST	ES UNA LISTA QUE CONTIENE LOS NÚMEROS DE SERIE DE LOS CERTIFICADOS REVOCADOS QUE NO HAN EXPIRADO AÚN. LAS CA MANTIENEN UNA O MÁS DE ESTAS LISTAS. CADA CERTIFICADO DEBE CONTENER LA LOCALIZACIÓN DEL CORRESPONDIENTE CRL EN LA EXTENSIÓN "CRL DISTRIBUTION POINTS CERTIFICATE".
OCSP: ONLINE CERTIFICATE STATUS PROTOCOL	PERMITE A LOS USUARIOS (TERCEROS) OBTENER EL ESTADO DE REVOCACIÓN DE UN ÚNICO CERTIFICADO A LA VEZ, Y EN UN MOMENTO DADO. LA LOCALIZACIÓN DE UN OCSP RESPONDER DE UNA CA ESTÁ CODIFICADA EN LA EXTENSIÓN "AUTHORITY INFORMATION ACCESS CERTIFICATE". ACTUALIZACIÓN MODERNA "OCSP STAPLING".



FEATURE	CRL (RFC 5280)	OCSP (RFC 2560, 6960)
DEFINITION	A PUBLISHED LIST OF REVOKED CERTIFICATES ISSUED BY A CERTIFICATE AUTHORITY (CA).	A REAL-TIME PROTOCOL THAT ALLOWS CLIENTS TO QUERY THE REVOCATION STATUS OF A SPECIFIC CERTIFICATE.
MECHANISM	CLIENTS DOWNLOAD THE ENTIRE CRL AND CHECK IF THEIR CERTIFICATE IS LISTED.	CLIENTS SEND A QUERY TO AN OCSP RESPONDER, WHICH PROVIDES THE REVOCATION STATUS OF THE SPECIFIC CERTIFICATE.
LATENCY	CAN BE HIGH, ESPECIALLY FOR LARGE CRLs.	GENERALLY LOW LATENCY, AS ONLY A SINGLE CERTIFICATE'S STATUS IS QUERIED.
SCALABILITY	CAN BE CHALLENGING FOR CAs WITH A LARGE NUMBER OF ISSUED CERTIFICATES.	MORE SCALABLE, AS IT AVOIDS THE NEED TO DISTRIBUTE LARGE CRLs.
PRIVACY	CAN REVEAL INFORMATION ABOUT OTHER REVOKED CERTIFICATES TO CLIENTS.	PRESERVES MORE PRIVACY, AS ONLY THE STATUS OF THE SPECIFIC CERTIFICATE IS REVEALED.
REAL-TIME UPDATES	LESS REAL-TIME, AS CRLs ARE TYPICALLY UPDATED PERIODICALLY.	PROVIDES NEAR REAL-TIME REVOCATION STATUS UPDATES.
NETWORK TRAFFIC	CAN GENERATE SIGNIFICANT NETWORK TRAFFIC, ESPECIALLY FOR CLIENTS WITH LIMITED BANDWIDTH.	GENERALLY, LESS NETWORK-INTENSIVE, AS ONLY A SINGLE QUERY IS SENT.



PROBLEMA DE GESTIÓN DE LLAVES:

- LA GESTIÓN DE LLAVES ES UN PROBLEMA DIFÍCIL EN LAS COMUNICACIONES SEGURAS QUE SE DEBE A RAZONES MÁS ALLÁ DE LAS TÉCNICAS CRIPTOGRÁFICAS UTILIZADAS.
- SE HAN DESARROLLADO FORMAS CRIPTOGRÁFICAMENTE SEGURAS DE GENERAR Y DISTRIBUIR LLAVES Y SON BASTANTE SÓLIDAS.
- EL ESLABÓN MÁS DÉBIL: LAS PERSONAS SON LOS RESPONSABLES DE MANTENER LA CONFIDENCIALIDAD DE LAS LLAVES PRIVADAS Y SECRETAS.
- MANTENER ESTAS LLAVES EN UN LUGAR SEGURO Y NO EXPONER SUS DATOS DE ACTIVACIÓN (CREDENCIAL) ES UNA TAREA SOCIALMENTE DIFÍCIL.



```

Certificate ::= SEQUENCE {
    tbsCertificate TbsCertificate,
    signatureValue BIT STRING }

TbsCertificate ::= SEQUENCE {
    version [0] EXPLICIT Version DEFAULT v1,
    serialNumber CertificateSerialNumber,
    signature AlgorithmIdentifier,
    issuer Name,
    validity Validity,
    subject Name,
    subjectPublicKeyInfo SubjectPublicKeyInfo,
    issuerUniqueID [1] IMPLICIT UniqueIdentifier OPTIONAL,
    -- If present, version MUST be v2 or v3
    subjectUniqueID [2] IMPLICIT UniqueIdentifier OPTIONAL,
    -- If present, version MUST be v2 or v3
    extensions [3] EXPLICIT Extensions OPTIONAL
    -- If present, version MUST be v3
}

Version ::= INTEGER { v1(0), v2(1), v3(2) }

CertificateSerialNumber ::= INTEGER

Validity ::= SEQUENCE {
    notBefore Time,
    notAfter Time }

Time ::= CHOICE {
    utcTime UTCTime,
    generalTime GeneralizedTime }

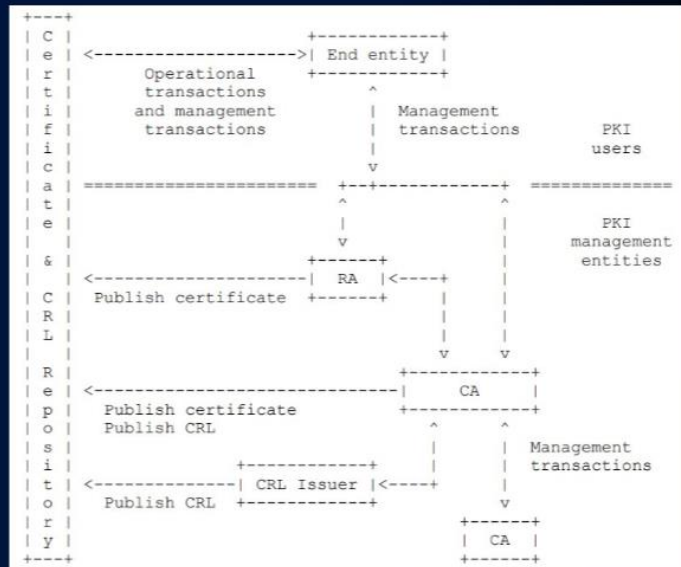
UniqueIdentifier ::= BIT STRING

SubjectPublicKeyInfo ::= SEQUENCE {
    algorithm AlgorithmIdentifier,
    subjectPublicKey BIT STRING }

Extensions ::= SEQUENCE SIZE (1..MAX) OF Extension

Extension ::= SEQUENCE {
    extnID OBJECT IDENTIFIER,
    critical BOOLEAN DEFAULT FALSE,
    extnValue OCTET STRING
    -- contains the DER encoding of an ASN.1 value
    -- corresponding to the extension type identified
    -- by extnID
}

```



<https://www.rfc-editor.org/rfc/pdf/rfc5280.txt.pdf>



Certificate Viewer: *.google.com

General Details

Certificate Hierarchy

- GTS Root R1
 - GTS CA 1C3
 - *.google.com

Certificate Fields

- *.google.com
 - Certificate
 - Version
 - Serial Number
 - Certificate Signature Algorithm
 - Issuer
 - Validity
 - Not Before

Field Value

CN = GTS CA 1C3
O = Google Trust Services LLC
C = US

Export...

Certificate Viewer: www.amazon.com

General Details

Certificate Hierarchy

- DigiCert Global Root G2
 - DigiCert Global CA G2
 - www.amazon.com

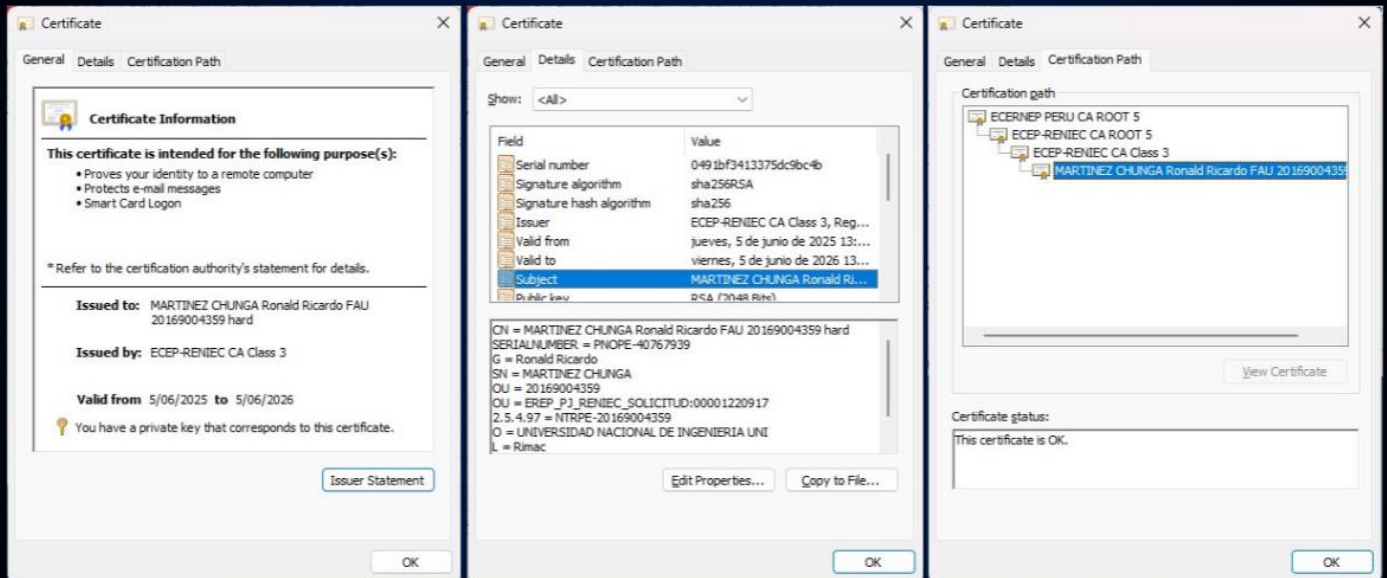
Certificate Fields

- www.amazon.com
 - Certificate
 - Version
 - Serial Number
 - Certificate Signature Algorithm
 - Issuer
 - Validity
 - Not Before

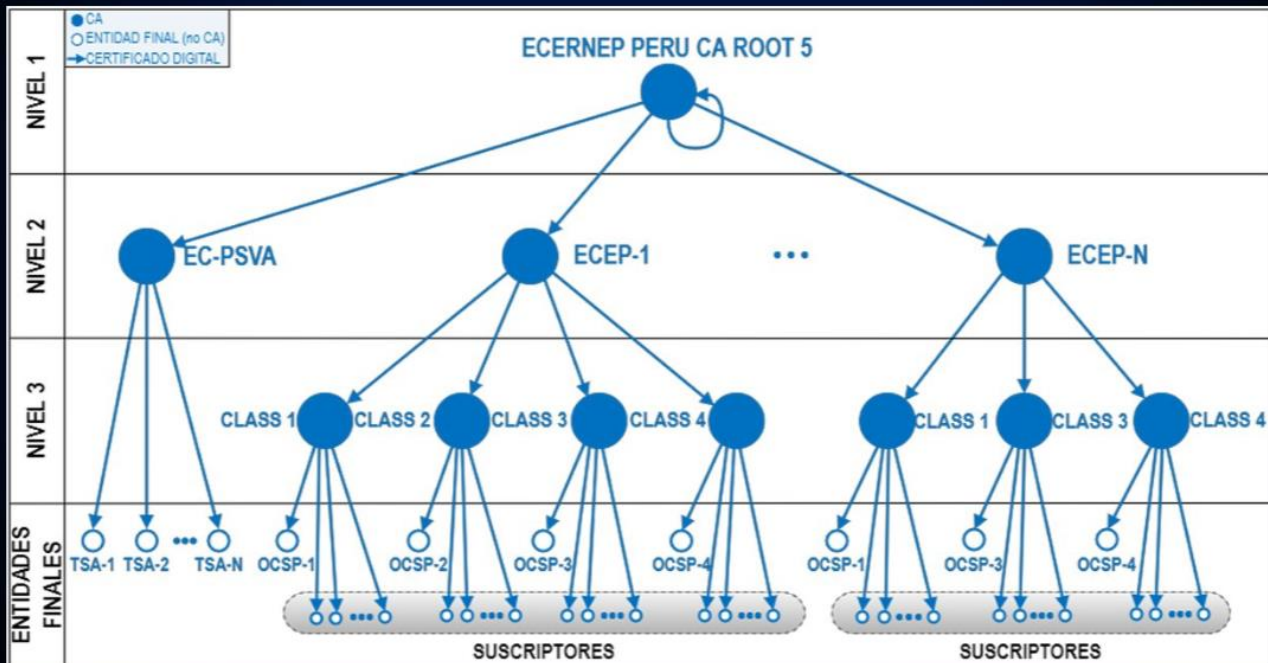
Field Value

CN = DigiCert Global CA G2
O = DigiCert Inc
C = US

Export...



17



18



UNIVERSIDAD NACIONAL DE INGENIERÍA

¡MUCHAS GRACIAS!